

Sprint 2: Authentication and Reliability

How SLE verifies Sendaza and prevents duplicate financial work

In progress

Current status: HMAC authentication, credential rotation support, raw-body verification, nonce replay protection, and the idempotency foundation exist on the feature branch. Outbox delivery, audit logging, full database race evidence, and the sprint gate remain unfinished.

Before and Goal

Sprint 0 created the app and Sprint 1 added exact registries. Sprint 2 adds three safety layers: prove the caller is Sendaza, reject copied signed requests, and ensure retrying one financial instruction cannot create two effects.

Signed Request Flow

```
Sendaza builds method + URL + timestamp + nonce + body hash
-> signs with HMAC secret
-> SLE validates time, credential, and signature
-> PostgreSQL atomically stores hashed nonce
-> controller may run
```

The database stores key metadata and nonce hashes, never the HMAC secret. One or two environment-backed keys support rotation without downtime.

Idempotency Flow

```
Mutation + Idempotency-Key
-> hash operation, client, method, exact URL, exact body
-> unique database identity: client + operation + key
    first = ACQUIRED | same complete = REPLAY
    different body = KEY_REUSED | running = IN_PROGRESS
```

A financial module must complete its idempotency record in the same PostgreSQL transaction as its financial state change.

Built So Far

- Canonical HMAC-SHA256 signing and constant-time verification.
- Environment-only secrets and two-key rotation support.
- Prisma credential metadata and atomic nonce repositories.
- Global NestJS authentication guard; health endpoints remain public.
- Exact raw request-body and request-target signing.
- Domain request hashing and database acquire/replay/conflict decisions.
- Mutation interceptor requiring an explicit stable operation and key.

System Link

Purchases, withdrawals, and manual actions will reuse these controls. Authentication fixes the caller identity as `sendaza-core`. Idempotency stops client retries from duplicating effects. The pending outbox will commit state and outbound Sendaza events together.

Rules Protected

- Customer frontends never call SLE directly.
- Secrets never enter PostgreSQL or logs.
- Every financial mutation needs a stored request hash.
- Process memory is not replay or idempotency truth.
- Infrastructure uncertainty fails closed.

Evidence and Remaining Work

After the idempotency increment, 13 suites and 61 tests passed with typecheck, lint, and both builds. Railway PostgreSQL rejected a duplicate credential nonce with code `23505`. A second live test using the actual Prisma repository produced exactly one acquired request and one in-progress request, then verified stored replay and conflicting-hash rejection. Temporary test data was removed.

- Add safe audit records.
- Add outbox leasing, retry, recovery, and quarantine.
- Run restart evidence and the complete Sprint 2 gate.

Next Sprint

Sprint 3 adds market-data providers and conversion routes on this authenticated, retry-safe, durable foundation.

Glossary

HMAC: shared-secret message signature. **Nonce:** one-time replay detector. **Idempotency:** retrying has no extra effect. **Request hash:** digest binding a key to content. **Outbox:** durable records for post-commit event delivery.

Feature branch and canonical SLE documents. Generated 31 August 2026; Sprint 2 remains in progress.